SIGPN-T — Security audit: consolidated specification

Status: **proposal, awaiting explicit approval.** Nothing in this document has been implemented. The audit was read-only: no source code, database, role, permission or production configuration was changed.

Date: 2026-11-09. Sources read: `prisma/schema.prisma`, `src/server/rbac/*`, `src/server/auth/*`, `src/server/hr/transfers.ts`, `src/server/org/service.ts`, the immutability triggers, and the environment settings.

1. Decisions approved by the client
2. Comparison table
3. Implementation lots (proposed order) p. 2
4. Open points (not decided, not invented)
5. What this specification does not change
6. Approval requested
7. Lot 1 — status (implemented 2026-11-09)

1. Decisions approved by the client

#	Decision	Status
1	The official organisation chart of the Chadian National Police is authoritative: DGPN, 23 provinces, about 300 commissariats, personnel. Administrators create and reorganise units. **No count is hardcoded.** The full chart will be supplied later.	Approved
2	Access follows the chain of command (supervision). Administrative geography is kept for filtering and statistics. A commissaire manages only their commissariat; a provincial director supervises the commissariats under their authority.	Approved
3	Technical administrators lose all operational powers: no approval of warrants, wanted notices or custody decisions, no access to confidential investigations.	Approved
4	MFA is mandatory for leadership, technical and security administrators, users with sensitive clearance, users who approve sensitive operations, and roles classed high-risk. Optional for ordinary users.	Approved
5	Clearances: three provisional tiers (standard, sensitive, confidential) until the Direction supplies the official levels.	Approved, provisional
6	Double approval only for sensitive roles and special permissions. Ordinary account creation needs one authorised approval.	Approved
7	Sensitive permissions: warrant approval, wanted notices, custody extension, role and permission changes, creation of technical or security administrators, viewing sensitive or confidential files, HR discipline and pay, export and deletion of data.	Approved
8	Single approval: the commissaire for station accounts, the provincial director for provincial accounts. Sensitive accounts: two approvers from different levels of the chain.	Approved
9	Separate the technical administrator (platform, no police data) from the security administrator (audit logs and accounts). Neither holds operational powers.	Approved
10	On reassignment: scope switches to the new unit at execution; sensitive permissions are suspended until a supervisor re-approves; sessions are revoked; open cases and tasks stay with the old unit until a supervisor reassigns them.	Approved
11	Audit log is never deleted and is hash-chained; the security administrator can verify the chain. The retention period is a legal question for the Direction.	Approved; period open
12	Reads of sensitive and confidential cases and documents, wanted persons and warrants are logged.	Approved
13	Sensitive accounts: shorter idle timeout (proposed 15 min) and one active session. API keys: mandatory expiry, rotation every 90 days, no sensitive permissions, visible and revocable by the security administrator.	Approved

2. Comparison table

Requirement	Existing	Proposed	Gap	Risk	Recommended action
RBAC	About 155 `module:action` permissions, 28 system roles, enforced server-side on pages, actions and API	Keep as is	None	Low	Keep
ABAC / org scoping	Scope levels NATIONAL, REGIONAL, DEPARTMENTAL, STATION, OWN based on the user's posting. `OWN` behaves like `STATION`	Scope derived from the chain of command, geography kept for filters; real `OWN`	No "reports to" relation; `OWN` not distinct	High: a director sees units by geography, not authority	Lot 2

TECHNOTCHAD

Hierarchical access	Region, department, station tree	Official levels (DGPN, province, commissariat, subordinate unit), editable by admins, no hardcoded counts	Level names differ; chain not modelled	Medium	Lot 2, after the official chart is supplied
Individual accounts	One account per person, password min 12, 90-day max age, history 5, lock after 5 failures	Keep	None found	Low	Keep
Module / action permissions	Present and tested (35 security tests)	Keep	None	Low	Keep
Special clearances	Only `isSensitive` on cases, `cases:view_sensitive`, `documents:view_confidential`	Three provisional tiers attached to users and to records	No clearance concept on users	High	Lot 3
Approval workflows	Four-eyes for warrants and search-warrant notices. None for account creation, role grants or permission changes	One generic mechanism, single or double approval by sensitivity	No generic mechanism	High	Lot 4
Admin / command separation	`SUPER_ADMIN` holds every permission except `hr:pay_*`	Technical admin and security admin, neither operational	Administrator can approve warrants and view everything	**Critical**	Lot 1
Secure audit log	Append-only by database trigger; no hash chain; reads logged only for HR dossiers, discipline, pay and public submissions	Hash chain, verification by the security admin, reads of sensitive records logged	No tamper evidence; incomplete read coverage	High	Lot 6
Revocation after reassignment	Transfer updates the user's station, region and department only; role and sessions unchanged	Sessions revoked, sensitive permissions suspended until re-approved	Old privileges survive a transfer	High	Lot 5
MFA	TOTP; 18 of 28 roles require it, set by role	Required by permission or clearance, optional otherwise	Rule is per role, not per sensitivity	Medium	Lot 3
Session management	Idle 60 min, absolute 10 h	Sensitive accounts: idle 15 min, one session	No stricter profile	Medium	Lot 7
API keys	Exist and are tested	Expiry, 90-day rotation, no sensitive permissions, admin visibility	Expiry and permission limits to be checked in detail	Medium	Lot 7
Departure / dismissal	Dismissal or departure disables the account	Keep	None	Low	Keep

3. Implementation lots (proposed order)

Every lot uses additive migrations only, keeps existing functionality, adds tests, and is committed separately. Each lot is shown to you before the next begins.

Lot	Content	Depends on	Main risk	Rollback
1. Separate administration	Create `TECH_ADMIN` and `SECURITY_ADMIN`; remove operational permissions from administrative roles; keep one documented emergency procedure so the system cannot be locked out	none	Locking everyone out of operational approvals during the change	Restore previous role-permission rows from the migration's saved copy
2. Organisation and chain of command	"Reports to" relation between units; editable unit levels and labels; scope computed from the chain; real `OWN` scope	Official chart (for final names only)	Wrong visibility if the chain is incomplete	Scope falls back to the current geographic rule
3. Sensitivity and clearance	Catalogue of sensitive permissions; three clearance tiers on users and records; MFA required by permission or clearance	Lot 1	Users blocked until they enrol MFA	Feature flag to switch the rule back to per-role

TECHNOTCHAD

4. Approval workflow	Generic request/approve mechanism; single approval for ordinary accounts, double for sensitive ones; applied to account creation, role changes and sensitive grants	Lots 1, 2, 3	Slows administration	Workflow disabled per action type
5. Reassignment effects	Scope switch, suspension of sensitive permissions, session revocation, supervisor re-approval	Lots 2, 4	Officers temporarily lose rights during a transfer	Suspension lifted manually by a supervisor
6. Audit hardening	Hash chain, verification page for the security admin, read logging of sensitive records	Lot 1	Slight write overhead	Chain verification is additive; logging can be turned off
7. Sessions and API keys	Sensitive-account timeout and single session; key expiry, rotation, permission limits	Lot 3	Shorter sessions annoy users	Settings are configuration values

4. Open points (not decided, not invented)

1. The full official organisation chart, including names of levels and units.
2. The official clearance levels and their names.
3. The audit retention period and archive rules.
4. Which exact roles the Direction classes as "high-risk".
5. The 15-minute idle timeout for sensitive accounts is a proposal, not a policy.
6. Whether the 48-hour custody limit and the sensitive-permission list match the law and the Direction's policy.

5. What this specification does not change

Existing data, accounts, APIs and screens stay as they are until a lot is approved. No police rank, structure or authorisation policy has been invented here: where the client has not supplied one, it appears above as an open point.

6. Approval requested

Please state which lots you approve, and in which order. Lots 1 and 6 can start without the official chart. Lot 2 can start with the current structure and be adjusted when the chart arrives.

7. Lot 1 — status (implemented 2026-11-09)

Done. Administration is separated from police command.

Item	Result
Technical administrator (`SUPER_ADMIN`, name changed)	11 platform permissions: settings, backups, demonstration data, organisation structure, role catalogue. No police permission, no audit log, no account management.
Security administrator (`SECURITY_ADMIN`, new)	15 permissions: accounts, sessions, security centre, audit log. No police permission.
Both roles	National, MFA required, locked against edition from the interface.
Existing databases	One-time step on start-up removes the operational permissions from `SUPER_ADMIN` (marked in `SystemSetting`, audited). Applied to the development database.
First accounts	`BOOTSTRAP_ADMIN_*` creates the technical administrator, `BOOTSTRAP_SECURITY_*` the security administrator (each only when none exists). Demonstration account `security.admin` added.
Tests	135 unit, 200 integration (6 new on the real server), 35 security, `tsc` clean. About 15 integration files moved from the old all-powerful `admin` account to the operational account that really holds the permission.

Choices made, to confirm.
1. The code `SUPER_ADMIN` is kept (and renamed "Technical Administrator") instead of creating `TECH_ADMIN`, so existing accounts, the last-administrator guards and the bootstrap keep working.
2. Interim rule until lot 4: the security administrator may grant any role except the two administrator roles without holding its permissions (granting is not holding). Without this rule nobody could create an investigator or desk account, since no other role holds all their permissions. Lot 4 puts approval on this.
3. The technical administrator keeps `roles:manage`. It can only grant permissions it holds, so it cannot make a role operational. Lot 4 puts double approval on role changes.
4. `POLICE_ADMIN` is not touched: it is a police role and still holds command permissions (warrants, wanted notices, custody extension). Whether it should is a question for the Direction.
5. Creating a second technical or security administrator is possible only through the bootstrap variables for now.

Not proven. The change has not been browsed in the interface (the administrator accounts need MFA enrolment, which was not done on the development data), and French and Arabic role labels were not looked at on screen.